

several advantages, such as lower cost and easier installation, and generally includes software support. COTS software may not, however, meet the entity's needs or security requirements. For example, COTS software may not integrate easily with existing software and may require further configuration to meet the entity's needs.

- **Custom software:** Custom software (e.g., core processing software) is developed for entities to provide custom functionality. Custom functionality can be developed by the entity or a third party (e.g., vendor or third-party service provider) by changing existing software through modules or functionality extended by add-ons (e.g., software extensions) to meet the entity's needs. Regardless of how custom software is developed, it should be designed to integrate with the existing enterprise software, hardware, and data. Risks associated with custom software may include higher support costs for modifying outdated software. Regular updates and maintenance of custom software may be more difficult because of the customization or lack of expertise.

Management should approve the software's use and ensure that the software meets the entity's infrastructure requirements (e.g., hardware requirements) and strategic objectives. Management should allocate resources to support the software (e.g., costs to maintain the software or support personnel), and personnel should have the expertise needed to maintain and patch the software. Refer to the *IT Handbook's* "[Development and Acquisition](#)" booklet for more information on software development and acquisition risk management.

V.C.2 Software Types

Entities use a variety of software to support day-to-day operations. These are common software types that support the infrastructure needs and business objectives. Regardless of the software used, management should be aware of and implement risk mitigations for general risks associated with software in the entity's infrastructure environment. To mitigate software vulnerabilities, management should keep the software current and appropriately patched. To mitigate unauthorized access to sensitive information, management should implement appropriate IAM controls, including activity monitoring. Risks associated with development, information security, and third-party service providers are discussed in the *IT Handbook's* "[Development and Acquisition](#)," "[Information Security](#)," and "[Outsourcing Technology Services](#)" booklets.

Software types found in server-based or cloud-based infrastructure environments typically include OS, core processing, productivity, enterprise, security, and system auditing software. The software types described in the following bulleted list can be proprietary (i.e., development is performed by designated employees or vendors) or open source, which is described in a sub-section after the bulleted list. There are also software types to address risks and controls specific to mainframe security and APIs described in the following sub-sections.

The following are general types of software found in both server-based and cloud-based infrastructure environments:

- **OS software:** An OS is a program that runs on a computer and provides a software platform on which other programs (e.g., application software and utility software⁵⁰) can run. An OS manages computer hardware resources and provides common services (e.g., access and security controls, file system maintenance, and communications management). There are numerous server, desktop, and laptop OSs, as well as mobile (e.g., tablet and smartphone) OSs. Regardless of the type used, if the OS is not maintained, other software may not function adequately or at all, which affects the entity's ability to conduct business. Therefore, management should oversee and maintain the OS, including testing and installing patches when appropriate. Because having access to the OS, including utility software, provides access to applications running on the OS platform, management should restrict and monitor administrator access to the OS and should limit the use of utility software.⁵¹
- **Core processing software:** Core processing software enables the processing of key banking functions (i.e., taking deposits and making loans) and other functions (e.g., statement rendering, payment processing, calculating interest, and customer relationship management [CRM]), and interfaces to other software (e.g., general ledger systems and reporting tools). This software should be appropriately restricted based on job responsibility and its use monitored because of the sensitive nature of the entity's and the customer's information and the impact on other systems (e.g., general ledger and customer and management reporting). Management should select core processing software with adequate capacity to support strategic goals and objectives (e.g., customer base growth or geographic diversity). The software should support usage spikes (e.g., daily, monthly, and quarterly), expected peak usage times (e.g., holidays), and future growth.
- **Productivity software:** Productivity software can refer to any software that helps to produce and manage data and improve the user's productivity. Management should consider using productivity software in its infrastructure environment to enable personnel to perform their job functions. Examples can include word processing, spreadsheet, database, video conferencing, and presentation software. "The line between web applications and locally installed applications has blurred over time to the point where a number of web application providers offer web versions of common desktop productivity tools, including word processors, spreadsheets, and calendars. ... As such, these web applications may need to support the ability to store and process mobile code associated with office documents (or any user-generated files), opening up web applications to many [risks associated with web applications]."⁵² "Common management and operational controls used to safeguard systems against other security threats also apply to active content."⁵³ These controls include IAM, configuration management, and monitoring of logs. There is a risk that data may fail to synchronize correctly, which could negatively affect data integrity. An attacking entity may intercept messages in transit and modify their contents, substitute other contents, or simply replay the transmission dialogue later in an attempt to disrupt the synchronization or integrity

⁵⁰ Utility software includes file compression, defragmentation, diagnostics, and performance optimization.

⁵¹ Some utility software can provide privileged access to other programs and data residing on the system.

⁵² Refer to [NIST SP 800-28 Version 2, Guidelines on Active Content and Mobile Code](#).

⁵³ [Ibid.](#)

of the information.⁵⁴ Mitigation strategies to address synchronization issues include version control, group collaboration, and other synchronization capabilities within a cloud (e.g., autosynch or file management).⁵⁵

- **Enterprise software:** Enterprise software helps management make better and more informed decisions through enterprise data aggregation. Enterprise software examples include communication, collaboration (e.g., SharePoint), CRM, digital and content creation, enterprise resource planning, project and portfolio management, and supply chain management. Enterprise software can encompass a vast array of subjects, methods, models, and reporting. Management should consider how enterprise software integrates in the entity's infrastructure environment. Because of the sensitive or critical nature of the information available within this type of software, management should limit access and editing capabilities and monitor user activity.
- **Security software:** Security software is designed with the goal of preventing an attacker from reaching the intended target or limiting the damage of an attack. The software can be designed to track the damage incurred from an attack. Malicious code continuously evolves; therefore, management should use security software that is current, deployed effectively, and designed to keep up with the evolution of malicious code. The software can be controlled by either a third-party service provider or the entity. Because of the sensitive security information contained within the software or technology assets being monitored by the software, administrative access to this type of software should be restricted. Security software types may include the following:
 - IAM.
 - Antivirus.
 - Encryption management.
 - Application firewall.
 - IDS/IPS.
 - Log management.
 - Security information and event management.
 - Patch and vulnerability management.

For more information, refer to the *IT Handbook's* "[Information Security](#)" booklet.

- **System auditing software:** System auditing software refers to automated programs that perform a variety of audit functions, such as database sampling and source code checks. Its purpose is to highlight exceptions to data and, in return, identify potential errors. Results can produce false positives and may require human intervention to verify that results are not accurate and make adjustments to reduce false positives over time. Management should use system auditing software to augment audit personnel and assist in the identification of gaps in infrastructure security and resilience. Once validated, audit results from the software can be used in conjunction with ML and AI. For example, the number of false positives can be reduced over time and the software can take certain actions to mitigate risk. Management

⁵⁴ [Ibid.](#)

⁵⁵ Refer to [NIST SP 800-146, Cloud Computing Synopsis and Recommendations.](#)

should document software intended for system audit use and define its purpose to ensure continued usefulness and reliability. For more information, refer to the *IT Handbook's* "[Audit](#)" booklet.

V.C.2(a) *Open Source Software*

Unlike proprietary software, open source software⁵⁶ can be accessed, used, modified, and shared by anyone.⁵⁷ Management may leverage a variety of open source software. Open source software may provide several advantages, including cost and availability. Management should identify unique security issues (e.g., public availability of the code, ability for users to alter the code, licensing issues, difficulty in tracking patches, and publicized exploits) with the use of open source software. Management should implement security controls and procedures to mitigate risks, including the following:

- Defining acceptable use (or restriction) guidelines, if appropriate, for open source software, including documenting a process for modifying and reviewing the code.
- Restricting access to unapproved shareware sites.
- Using tools to help discover unapproved open source software.
- Identifying the type and version of open source software in use, where it is used within the entity, and its purpose.
- Implementing version and patch control guidelines for open source software in use.
- Monitoring for vulnerabilities of the open source software employed by the entity.

Open source components may be present in third-party software used by the entity; therefore, management should evaluate the implications of those components and address their use in contract provisions. Information regarding open source software or components should be evaluated by management during its software due diligence. Refer to the *IT Handbook's* "[Development and Acquisition](#)" booklet for further information.

V.C.2(b) *Mainframe Security Software*

Using a mainframe computer in the infrastructure environment presents specific security risks. Mainframes may provide a single point of control or access point to an entity's systems, applications, and information repositories. The risks include inappropriate user access, unauthorized access to mission-critical data, inappropriate audit log settings, inadequate monitoring and alerting, untimely patch management, and ineffective auditing of mainframe security. To mitigate these risks, management should implement the following:

- Access controls, including role-based access control, segregation of duties, and multifactor authentication.

⁵⁶ Examples of open source software include the following: CRM (e.g., Flowlu, HubSpot CRM, and YetiForce); project management (e.g., Trello); blockchain (e.g., Ethereum, Hyperledger, and IOTA); internet browser (e.g., Firefox); productivity (e.g., LibreOffice and GIMP); OS (e.g., Linux, BSD, and Unix); and security (e.g., Nessus, Snort, Nagios, Nmap, Metasploit, Wireshark, and Kali Linux).

⁵⁷ Refer to [NIST Suborder 6106.01, "Open Source Code."](#)

- Security controls (e.g., password complexity, inactivity timeout, and login restrictions).
- Encryption of sensitive information.
- Activity log settings that include user access, failed login attempts, and security setting changes.
- Real-time monitoring and alerting of mainframe activity.
- Timely patch management processes.
- Mainframe security auditing (e.g., regular review of security controls and validation of privileges, roles, and access profiles to limit excessive access and provide for timely removal of unnecessary access).

System and security administrator access (e.g., super user privileges) are necessary to perform specific mainframe activities; such access, however, creates a potential for misuse. Management should have an independent method to closely monitor the use of these privileged accounts.

There are several software-based access control security tools⁵⁸ available for managing security of critical mainframe system resources. These tools are generally add-on software products that provide security for a mainframe and protect system resources by granting access only to authorized users. Tools provide the ability to do the following:

- Identify, authorize, and authenticate users.
- Safeguard sensitive information.
- Log and report attempts of unauthorized access to sensitive information.
- Provide system and security administrator controls.

Mainframe experts may not be readily available. Therefore, management should maintain appropriate expertise to understand the unique security features of mainframe computers.

V.C.2(c) *Application Programming Interfaces*

APIs are software code that allows two or more different programs to communicate with each other. Entities use APIs (considered a form of middleware) to connect services and to transfer data. Broken, exposed, or compromised APIs can be exploited by malicious actors and used in data breaches (e.g., compromise of financial and personal data) or for other purposes (e.g., preventing availability) by exposing the endpoints or compromising the authentication tokens. Security needs for APIs should be assessed and implemented to mitigate risks of exposing sensitive customer or entity information.⁵⁹ Therefore, management should address authorization, authentication, and encryption; API security tools and gateways with controls for requests and responses; sensitive data filtering; restriction on size and number of resources requested; identification of API request checkpoints for information leaving the network; and appropriate API logging and monitoring. Examples of security controls include the following:

⁵⁸ Examples of industry tools include [Resource Access Control Facility \(RACF\) from IBM](#), [CA Access Control Facility \(ACF2\) from Broadcom](#), and [CA Top Secret from Broadcom](#).

⁵⁹ The [OWASP API Security Project](#) discusses API security issues and controls.

- Secure IPs (e.g., HTTPS) to encrypt data during transmission from the web browser to a web server.
- Password hashing to validate the integrity of the message.
- Restriction of secret information (e.g., API keys, session tokens, and user IDs) from website addresses to prevent unnecessary information transmission.
- Industry standard authorization protocols⁶⁰ to securely authenticate users.
- Strong validation to ensure a user knows what to input (i.e., client-side validation) and on the web server to ensure data are accurate and in the correct format (i.e., server-side validation) to help mitigate malicious attacks.
- Time stamping of API requests to provide traceability of the request.
- Rate limiting of API calls to protect against malicious attacks (e.g., DDOS).
- API traffic monitoring to determine the locations from where requests originate allowing the ability to take action (e.g., monitor activity or block IP addresses).
- API gateways configured appropriately throughout the entity's IT environment to facilitate principles of least privilege to information and services.

There are three primary types of APIs. An entity may use more than one of the following within its infrastructure:

- **Internal or private APIs:** Internal or private APIs are restricted from external access. They are used by internal teams or business units to access internal data, services, and tools. Advantages of using internal APIs include the following:
 - Standardization of connections to internal services (e.g., eliminating hard-coded connections).
 - Decreased code development time through use of existing and already tested APIs.
 - Control over coding practices (e.g., secure coding).
 - Access restrictions over the API.
 - Auditability of API access and requests.Management should implement an appropriate level of security before internal APIs are made available for use by other entity business units.
- **Public or open APIs:** Public or open APIs (also referred to as third-party APIs) are accessible by external parties (e.g., developers). External parties register for access with the entity and, in return, receive an API key.⁶¹ In some cases, however, no registration is required. Management should implement adequate security and restrictions to protect sensitive customer and entity data. Management should perform appropriate testing to verify the adequacy of security controls before and after going public.
- **APIs between customers and unaffiliated third parties:** In this situation, the relationship is between the customer and a third party (e.g., a fintech firm that is separate from the financial institution where the customer has the account). This type of API has a specific purpose and may have a fee associated with its usage. As part of its customer awareness

⁶⁰ For an example refer to Internet Engineering Task Force, [RFC 7591, OAuth 2.0 Dynamic Client Registration Protocol](#), DOI 10.17487/RFC7591, July 2015.

⁶¹ An API key allows access to certain services and data.

program,⁶² management should make security awareness information (including the protection of customer information) available to its customers. The security awareness information should address protections available and not available when the customer allows access to its data through the use of unaffiliated third-party API services. Better-informed customers bolster the safety and soundness of an entity, consumer financial protection, and compliance with applicable laws and regulations.

V.C.3 Software Hosting

Software can be hosted internally at the entity, externally at the entity's third-party service provider, or in a combination of the two (e.g., using cloud infrastructure to manage capacity or for continuity and resilience purposes). Risks associated with software hosting include internal and external malicious actors. Threat modeling may help management determine the relevant risks from these actors and implement appropriate security controls to mitigate those security risks. Refer to the *IT Handbook's* "[Information Security](#)" booklet for more information.

- **Internally hosted software:** Internally hosted (also referred to as on-premise) software refers to software that the entity hosts and manages. Usually, the internal IT department is responsible for software administration. When hosting software internally, there is a risk that the entity personnel does not have the appropriate skills and expertise to effectively manage the hosting environment. Management should identify personnel (e.g., internal or third party) with relevant skills and expertise and allocate resources to provide necessary training to maintain their knowledge. If the entity develops software, management should use a system development life cycle that incorporates security to limit the number and severity of vulnerabilities in the software.
- **Externally hosted software:** Externally hosted software (also known as hosted services) is hosted at an entity's third-party service provider. Access generally occurs through an internet connection. Hosted services may include core processing, web hosting (e.g., online banking and website), off-site backup, and virtual desktop infrastructure. Possible risks with externally hosted software include a lack of control over the infrastructure and any changes made to it by the third-party service provider. Management should have contract provisions addressing the notification of infrastructure changes and the third party's use of any subcontractors (sometimes referred to as "fourth parties"). For more information, refer to the *IT Handbook's* "[Outsourcing Technology Services](#)" booklet.
- **Hybrid hosted software arrangement:** A hybrid hosted software arrangement refers to an agreement involving software that resides at the entity (on premise) and on the third-party service provider's servers (e.g., productivity software as a service). Examples of this arrangement include the following:
 - Internally deployed software at the entity where all data are maintained on the third-party service provider's servers.

⁶² See FFIEC [Authentication in an Internet Banking Environment](#) and FFIEC [Supplement to Authentication in an Internet Banking Environment](#) for additional information.

- Software intellectual property hosted on the third-party service provider's servers and available in an "offline"⁶³ implementation (e.g., productivity software) at the entity. The software has the ability to synchronize once the user has reconnected to the third-party service provider.
- Use of a cloud service provider's infrastructure for additional capacity or for continuity and resilience purposes, when necessary, although most of the infrastructure is managed at the entity.

When operating in a hybrid hosted software arrangement, the entity may not have complete access to the software intellectual property or its data. For hybrid and externally hosted software, if full functionality of the software or data is necessary and the connection to the third-party service provider is interrupted, the entity could experience significant loss (e.g., data, functionality, or business), depending on the arrangement. Even though a level of offline functionality may be available to the entity, that functionality may be limited. When an entity depends on the third-party service provider's ability to function adequately, management should perform an adequate risk assessment to prepare for a potential service interruption.

V.D Environmental Controls

Environmental controls are mitigating strategies designed to detect and prevent against natural, mechanical, and man-made risks and threats to the entity's buildings and facilities and the affected personnel and infrastructure within them. Environmental controls include the following:

- HVAC.
- Smoke and fire.
- Water.
- Power.

Without effectively designed and implemented environmental controls, an entity's infrastructure may be exposed to risks that could reduce system resilience and reliability.⁶⁴ Environmental controls help management identify and mitigate infrastructure and operational issues, such as loss of connectivity and availability of processing caused by theft, fire, flood, mechanical failure, and power failures, in a timely manner. Management should develop, document, and implement environmental control policies and procedures to safeguard facilities, technology, data, and people. For more information, refer to the *IT Handbook's* "[Business Continuity Management](#)" booklet.

Remote monitoring systems are available to monitor the entity's infrastructure environmental controls and allow management to receive timely notifications and monitoring reports. Alerts can be sent via email or text message. These systems can be managed and monitored internally or through a third-party service provider. Any environmental controls (including IoT devices used

⁶³ Offline in this manner means that the application is still available for use when disconnected from the third-party service provider.

⁶⁴ Refer to ISO/IEC 27002:2013 [Information Security Management Chapter 11: Physical and Environmental Security](#).

for environmental monitoring) that can be managed through remote access, whether by a third-party service provider or not, should have appropriate access controls, monitoring of remote access activity, and regular review of privileges. Third-party service provider access for maintenance (e.g., system repair) and administrative purposes (e.g., billing) also should be appropriately controlled. For more information, refer to the *IT Handbook's* "[Outsourcing Technology Services](#)" and "[Information Security](#)" booklets.

V.D.1 Heating, Ventilation, and Air Conditioning

Management should implement controls to maintain appropriate temperature and humidity levels at facilities (e.g., data centers and server rooms) hosting the entity's IT infrastructure. Management should monitor HVAC. Automatic temperature and humidity controls help management identify and mitigate fluctuations that may adversely affect IT infrastructure. Commensurate with risk to the entity, management should consider implementing automated monitoring and mitigating controls that provide an alarm or notification of significant temperature changes. Management also should consider the entity's need for redundant HVAC equipment components. For more information, refer to the *IT Handbook's* "[Business Continuity Management](#)" booklet.

V.D.2 Smoke and Fire

Risks of smoke and fire to an entity's infrastructure include failed or suppressed performance of systems or complete destruction of its infrastructure. Various methods are available to detect, suppress, or extinguish fire (e.g., portable fire extinguishers or systems for air sampling, active fire suppression, wet pipe, dry pipe, pre-action,⁶⁵ gas, chemical,⁶⁶ or oxygen-removal). Management should evaluate the following:

- Determining the most appropriate smoke and fire detection systems for the entity, based on the design and contents of its facilities and infrastructure.
- Installing smoke and fire detectors in appropriate locations throughout the facility (e.g., data centers, business offices, and computer rooms).
- Implementing devices and systems for smoke detection, fire suppression, and fire detection that are supported by an independent energy source.
- Inspecting facilities for potential fire hazards using authorized and qualified inspectors and resolving identified deficiencies within an agreed-upon time frame.
- Training personnel on their roles and responsibilities.

All systems should be evaluated for their advantages and disadvantages. For example, wet pipe, dry pipe, or pre-action systems will suppress fire, but they may create problems associated with water in the facility. To provide continuous protection of facility assets, the fire suppression

⁶⁵ According to [NIST NCSTAR 1-4B, Fire Suppressions Systems](#), pre-action systems are different than both wet-pipe and dry-pipe sprinkler systems. In pre-action systems, water is not normally stored in the system piping like a wet-type sprinkler system. The water is kept out of the system of piping by a pre-action (deluge) valve until the system response is required as a result of the opening of a sprinkler and/or the activation of a detection device.

⁶⁶ These systems are also known as clean agent systems.

system should be operational even after business hours. If an entity's fire suppression system includes oxygen removal, management should be aware of potential risks to personnel with that system type and implement compensating personnel protection controls. Smoke and fire detection provisions should be addressed in the contract for the entity's third-party hosted infrastructure.

V.D.3 Water

Water use (e.g., fire suppression system, break room, restrooms, and HVAC systems) in the facility can cause damage to an entity's infrastructure. Water damage caused by environmental issues (e.g., flood or hurricane) is addressed in the *IT Handbook's* "[Business Continuity Management](#)" booklet. Water leaks under raised floors or in ceilings are not easily visible and can cause serious damage to computer equipment and cabling. For this reason, management should consider use of water detectors in both spaces to alert management in a timely manner. Commensurate with risk to the organization, management should consider automated mechanisms to detect the presence of water near IT infrastructure and provide alerts to appropriate personnel.

V.D.4 Power

Power compatibility and quality issues (e.g., appropriate power supply, power surges or sags, or inconsistent power delivery) can damage computer equipment or cause data loss or corruption. Management should take reasonable steps to protect computing equipment from inconsistent and "dirty power"⁶⁷ sources as equipment should have a consistent power source. Management should consider a long-term alternate power supply for information systems that provides the necessary operational capability in the event of extended power loss.⁶⁸ Long-term backup power can be manually or automatically activated. Management should consider using the following:

- Independent electrical feeds drawing from separate power grids. When multiple feeds or backup power generators are used, automatic fail-over to a live power source should be considered. When power is available only through one grid or one provider, management should evaluate and mitigate the risk in other ways (e.g., using generator(s) or batteries).
- Methods to monitor, condition, or stabilize the electricity source voltage to minimize the effects of power fluctuations with specialized devices (e.g., surge protectors or capacitors).
- Appropriate power configurations based on the entity's power needs.
- Alternative, or backup, power sources for IT facilities independent of local power grids. Those sources could include a combination of uninterruptible power supply (also referred to as UPS) and generators⁶⁹ powered by diesel or natural gas, and management should consider

⁶⁷ Refer to Martzloff, François, "[A New IEC Standard on the Measurement of Power Quality Parameters.](#)" The report uses dirty power to describe a power line where disturbances (e.g., outages, voltage spikes, and drop-outs) occur. NIST, 2000.

⁶⁸ Refer to [NIST SP 800-53 Rev. 5, Security and Privacy Controls for Federal Information Systems and Organizations - PE-11 Emergency Power.](#)

⁶⁹ The generator should run on something other than electricity.